

API Test Cases

Library Management System

Test Design Team (Coders & Non-Coders)

June 8, 2025

Note: These test cases are designed to validate the RESTful API of the Library Management System. They are derived from the Software Requirements Specification (SRS) and are intended to be executed using a tool like Postman. Both user-centric scenarios and technical validations are included.

II. API Test Cases

Table 1: API Test Cases

Test Case ID	Objective	API Endpoint & Method	Request Body / Parameters & Expected Results
Sub-Section: Authentication API ('/api/auth')			
TC_API_AUTH_001	Successful Librarian Login	POST '/api/auth/login'	Request Body (JSON): <pre> 1 { 2 "email": "librarian@example.com", 3 "password": "valid_password" 4 } </pre> Expected Result: • Status Code: 200 OK • Response Body: Contains user object with 'isAdmin: true' and an authentication token/session cookie.
TC_API_AUTH_002	Successful Member Login	POST '/api/auth/login'	Request Body (JSON): <pre> 1 { 2 "email": "member@example.com", 3 "password": "valid_password" 4 } </pre> Expected Result: • Status Code: 200 OK • Response Body: Contains user object with 'isAdmin: false' and an authentication token/session cookie.
TC_API_AUTH_003	Login with invalid password	POST '/api/auth/login'	Request Body (JSON): <pre> 1 { 2 "email": "librarian@example.com", 3 "password": "invalid_password" 4 } </pre> Expected Result: • Status Code: 401 Unauthorized (or similar) • Response Body: Contains an appropriate error message.
TC_API_AUTH_004	Librarian registers a new member	POST '/api/auth/register' (Requires Librarian auth)	Request Body (JSON): <pre> 1 { 2 "name": "New Member", 3 "email": "new.member@example.com", 4 "password": "strong_password", 5 "isAdmin": false 6 } </pre> Expected Result: • Status Code: 201 Created • Response Body: Confirmation message. The user record is created in the database with a hashed password.
Continued on next page			

Table 1 – continued from previous page

Test Case ID	Objective	API Endpoint & Method	Request Body / Parameters & Expected Results
TC_API_AUTH_005	Attempt to register with an existing email	POST '/api/auth/register' (Requires Librarian auth)	Request Body (JSON): <pre>{ "name": "Another Member", "email": "member@example.com", "password": "another_password", "isAdmin": false }</pre> Expected Result: • Status Code: 400 Bad Request (or similar) • Response Body: Error message indicating the user already exists.
TC_API_AUTH_006	Member attempts to access user registration endpoint	POST '/api/auth/register' (Requires Member auth)	Request Body (JSON): (any valid user data) Expected Result: • Status Code: 403 Forbidden • Response Body: Error message indicating insufficient permissions, as only librarians can register users.
TC_API_AUTH_007	Successful Logout	GET '/api/auth/logout' (Requires any user auth)	Request Body: N/A Expected Result: • Status Code: 200 OK (or redirect) • The user's session is terminated. Subsequent requests to protected endpoints should fail.
Sub-Section: Book Management API ('/api/book')			
TC_API_BOOK_001	Librarian adds a new book	POST '/api/book/add' (Requires Librarian auth)	Request Body (JSON): <pre>{ "name": "The Art of Software Testing", "isbn": "978-1118031534", "isAvailable": true }</pre> Expected Result: • Status Code: 201 Created • Response Body: The newly created book object.
TC_API_BOOK_002	Member attempts to add a new book	POST '/api/book/add' (Requires Member auth)	Request Body (JSON): (any valid book data) Expected Result: • Status Code: 403 Forbidden • Response Body: Error message indicating insufficient permissions. Librarians have exclusive add rights.
TC_API_BOOK_003	Any user gets a list of all books	GET '/api/book/getAll' (Public or Member auth)	Request Body: N/A Expected Result: • Status Code: 200 OK • Response Body: An array of book objects.
TC_API_BOOK_004	Librarian deletes a book	DELETE '/api/book/delete/id' (Requires Librarian auth)	Parameters: URL parameter 'id' of an existing book. Expected Result: • Status Code: 200 OK (or 204 No Content) • Response Body: Success message. The book is removed from the database.

Continued on next page

Table 1 – continued from previous page

Test Case ID	Objective	API Endpoint & Method	Request Body / Parameters & Expected Results
TC_API_BOOK_005	Unauthenticated user attempts to delete a book	DELETE '/api/book/delete/id' (No auth)	Parameters: URL parameter 'id' of an existing book. Expected Result: • Status Code: 401 Unauthorized • Response Body: Error message indicating authentication is required.
Sub-Section: Borrowal Management API ('/api/borrowal')			
TC_API_BORROW_001	Member borrows an available book for themselves	POST '/api/borrowal/add' (Requires Member auth)	Request Body (JSON): <pre>{ "bookId": "valid_book_id", "memberId": "current_user_id" }</pre> Expected Result: • Status Code: 201 Created • Response Body: The new borrowal record. The book's availability may be updated.
TC_API_BORROW_002	Member attempts to borrow a book for another member	POST '/api/borrowal/add' (Requires Member auth)	Request Body (JSON): <pre>{ "bookId": "valid_book_id", "memberId": "another_user_id" }</pre> Expected Result: • Status Code: 403 Forbidden • Response Body: Error message. The API must enforce that the 'memberId' in the request matches the authenticated user's ID.
TC_API_BORROW_003	Librarian updates a borrowal status (e.g., to 'Returned')	PUT '/api/borrowal/update/id' (Requires Librarian auth)	Parameters: URL parameter 'id' of an existing borrowal. Request Body (JSON): <pre>{ "status": "Returned" }</pre> Expected Result: • Status Code: 200 OK • Response Body: The updated borrowal object.
TC_API_BORROW_004	Member attempts to view all borrowals in the system	GET '/api/borrowal/getAll' (Requires Member auth)	Request Body: N/A Expected Result: • Status Code: 200 OK • Response Body: An array containing only the borrowal records for the authenticated member. The API should not leak other users' data.
Sub-Section: Security & Input Validation			
TC_API_SEC_001	Verify password hash is not returned on user lookup	GET '/api/user/get/id' (Requires Librarian auth)	Parameters: URL parameter 'id' for any user. Expected Result: • Status Code: 200 OK • Response Body: The user object must not contain the 'hash' or 'salt' fields.

Continued on next page

Table 1 – continued from previous page

Test Case ID	Objective	API Endpoint & Method	Request Body / Parameters & Expected Results
TC_API_SEC_002	Attempt basic SQL Injection (or NoSQL equivalent)	POST '/api/auth/login'	Request Body (JSON): <pre> 1 { 2 "email": "' OR '1'='1", 3 "password": "' OR '1'='1" 4 } </pre> Expected Result: • Status Code: 401 Unauthorized (or 400 Bad Request) • Response Body: Normal login failure message. The system must not be compromised. This validates server-side input validation.